AI & Cybersecurity – Day 3

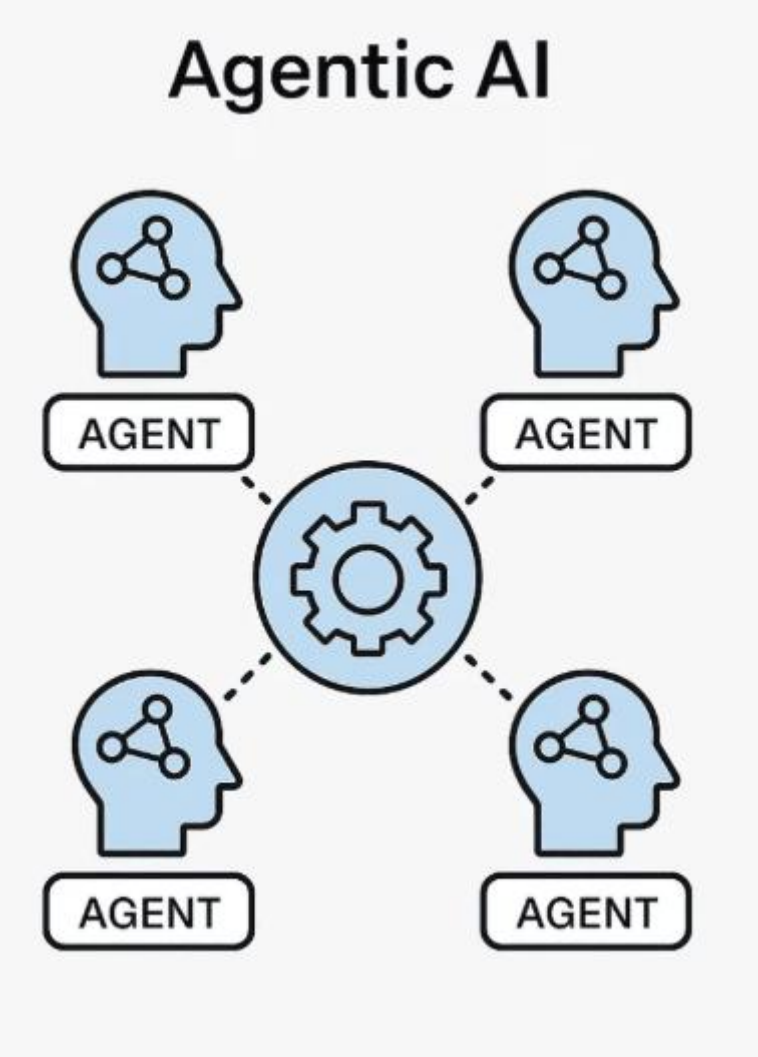
AGENTIC AI RISKS & MITIGATIONS

- Aakash K

Agentic AI

- AI Agent vs Agentic AI

- Spectrum of Agency
- Owasp Agentic AI Top 10



© National University of Singapore. All Rights Reserved.

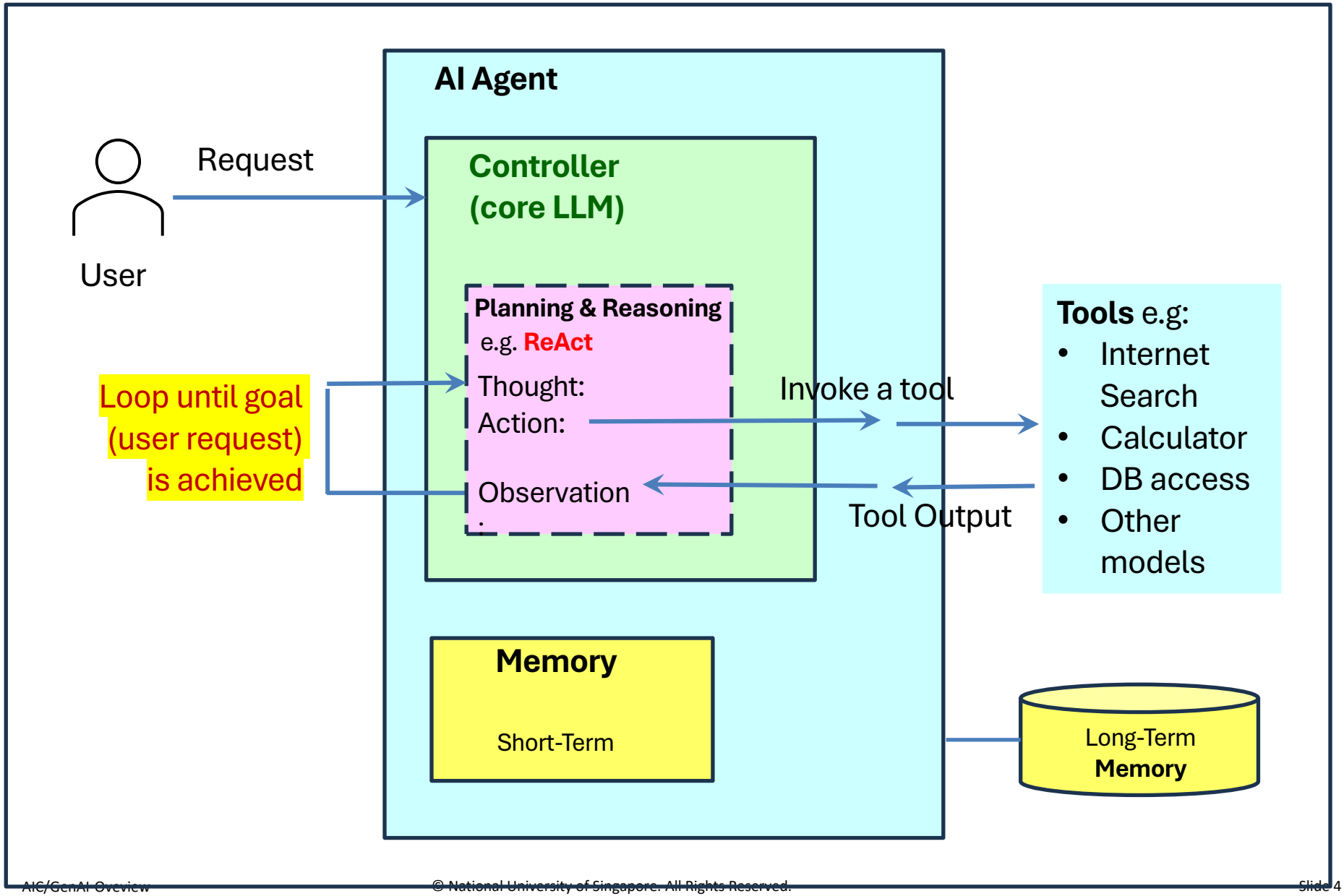
Learning Outcome

At the end of this module, the learner should be able to:

- Identify risks related to Agentic AI systems and
- Recommend corresponding mitigations.

© National University of Singapore. All Rights Reserved.

AI Agent



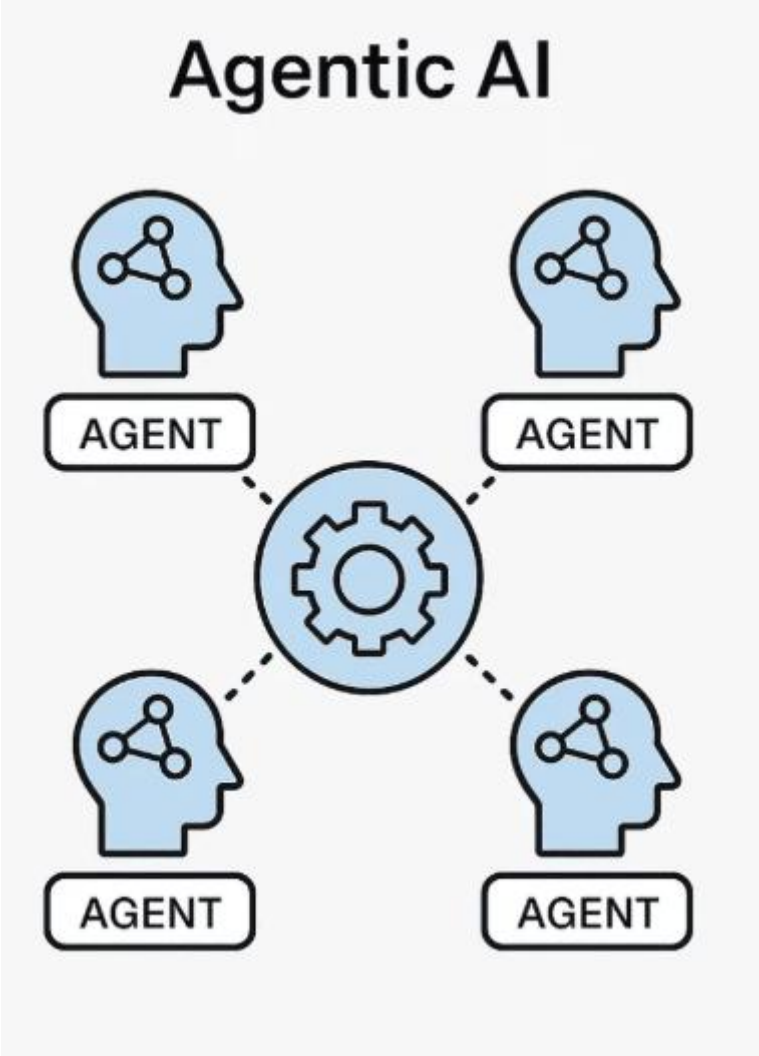
© National University of Singapore. All Rights Reserved.

What is an Agentic AI System?

- An agentic AI system consists of *one or multiple AI agents* working in concert to *accomplish complex tasks* or solve complex problems.

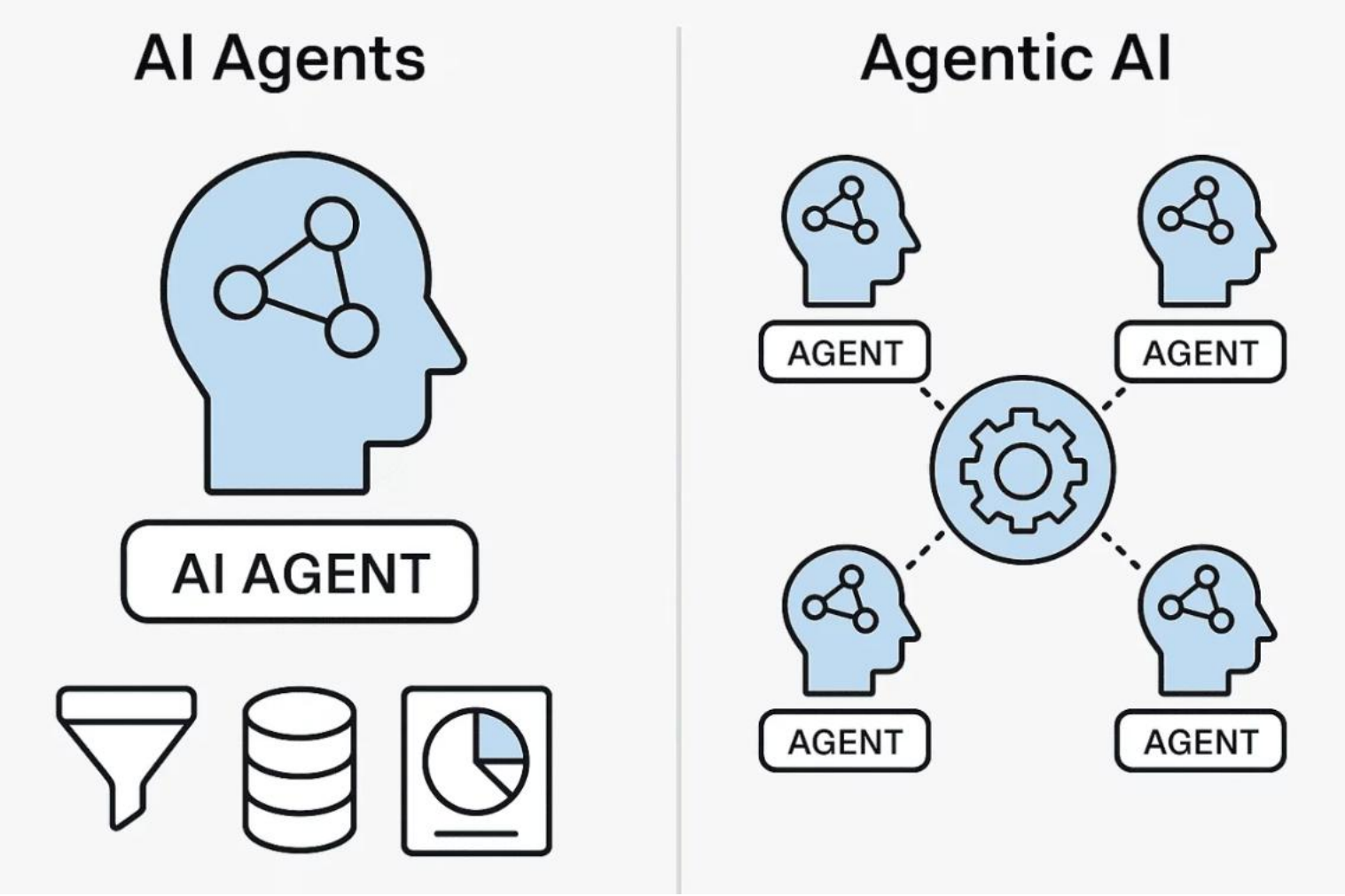
- In Agentic AI systems, *LLM outputs control the workflow*.

- There is a *spectrum of agency* depending on how much influence the LLM output has on the *system's overall workflow*.



© National University of Singapore. All Rights Reserved.

AI Agents vs Agentic AI



https://theaiinsider.tech/2025/05/19/whats-the-difference-between-ai-agents-and-agentic-ai-new-study-separates-signal-from-noise-in-the-ai-agent-boom/

© National University of Singapore. All Rights Reserved.

Spectrum of Agency

Level	Name	Description	Example
0	**No agency (response-only)**	Generates *answers only*; no tools, no system actions.	"Explain what RAG is" → *returns a text explanation.*
1	**Suggestive (human executes)**	*Recommends steps/checklists*; user performs all actions.	"How to triage phishing?" → *provides a runbook* for the analyst to follow.
2	**Tool-assisted (read-only)**	Uses tools to *gather info* (search/RAG/calcs) *but doesn't change systems.*	Pulls relevant KB pages + *summarizes logs, but doesn't open/close tickets.*
3	**Action-capable with approval**	*Prepares changes* and can *execute them only after explicit human approval.*	Drafts a firewall rule or blocks an IP, *then waits for "Approve" to apply.*
4	**Semi-autonomous (bounded)**	*Executes low-risk actions* within strict policy; escalates high-risk actions.	*Auto-creates incident tickets,* collects evidence, isolates a test host under policy.
5	**Fully autonomous**	*Plans and executes end-to-end with minimal oversight; highest-risk mode.*	*Detects incident → contains → remediates* → communicates without human review.

© National University of Singapore. All Rights Reserved.

FairPrice – Case study

Retail "agentic assistants" in the store: FairPrice deployed multiple AI agents in its "Store of Tomorrow" to deliver conversational, personalized shopping help via Smart Carts.

Multi-agent orchestration (not just one chatbot): The Smart Cart experience is described as several agents working together—conversation/speech, product search, and a knowledge/RAG agent for grounded suggestions.

Core agentic building blocks: They used Google Cloud's Agent Development Kit (ADK) and open standards like Model Context Protocol (MCP) to build and integrate agents.

RAG + grounding to trusted sources: A "knowledge agent" pattern is used to retrieve and summarize information (e.g., recipes/pairings, product details) rather than purely generating from memory—classic RAG/grounded generation.

FairPrice Group, Singapore's Largest Retailer, Deepens AI Collaboration with Google Cloud, Brings New Agentic Applications to its 'Store of Tomorrow' and Workforce

Google Cloud-enabled agentic AI assistants help customers shop smarter and save more at the newly opened FairPrice Finest outlet in Punggol Digital District

With Google Agentspace, FairPrice Group democratizes access to AI agents for its employees

FairPrice Group's creative agent, developed using Google's industry-leading generative media models, reduces the time and cost required to create ads for in-store promotions

SHARE:

Singapore, Aug. 28, 2025 – Google Cloud and Singapore's largest retailer FairPrice Group (FPG) today announced an expanded multi-year collaboration to

https://www.googlecloudpresscorner.com/2025-08-27-FairPrice-Group,-Singapores-Largest-Retailer,-Deepens-AI-Collaboration-with-Google-Cloud,-Brings-New-Agentic-Applications-to-its-Store-of-Tomorrow-and-Workforce

© National University of Singapore. All Rights Reserved.

Agentic AI Risks

- **Classical cybersecurity risks** as they have underlying software infrastructure components.
- **Inherited risks from LLMs** such as prompt injection. The risks discussed under the *GenAI Risks and Mitigations* module would apply here.
- **New risks** arising from **agentic components** such as tool use, memory, instructions and protocols

https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/

© National University of Singapore. All Rights Reserved.

OWASP Agentic AI Top 10

OWASP	Name	Description	Example	Mitigation
ASI01	**Agent Goal Hijack**	Attackers manipulate an agent's objectives, planning, or decision pathways via untrusted natural-language inputs. Leads to redirected multi-step actions and harmful outcomes beyond a single bad response.	Hidden prompt in a doc/email causes the agent to exfiltrate data or change task scope.	-Treat all NL inputs as untrusted + apply injection safeguards. -Lock goals/system prompts + require approval for goal changes.
ASI02	**Tool Misuse & Exploitation**	Agent misuses legitimate tools within its granted permissions due to unsafe delegation or manipulation. Can delete data, exfiltrate info, or trigger cost/DoS via chaining and loops.	Agent is tricked into running a "cleanup" script or chaining CRM → email to leak a customer list.	-Least-privilege per tool (scopes, rate, egress allowlist). -Policy gate + HITL for destructive/high-impact tool calls.
ASI03	**Identity & Privilege Abuse**	Exploits delegation chains, role inheritance, cached credentials, or cross-agent trust to escalate access. Creates attribution gaps and breaks least privilege in agentic workflows.	Low-priv agent relays "internal" request or High-priv agent executes payment without re-checking intent.	-Task-scoped, time-bound tokens; isolate per-session identity/context. -Re-verify authorization per privileged step + HITL for escalation.

© National University of Singapore. All Rights Reserved.

OWASP Agentic AI Top 10

OWASP	Name	Description	Example	Mitigation
ASI04	**Agentic Supply Chain Vulnerabilities**	Third-party agents/tools/prompts/registries can be malicious or tampered with, often loaded dynamically at runtime. Poisoned descriptors/templates can cascade across workflows at scale.	Malicious MCP server/tool descriptor impersonates a legit service and BCCs emails to attacker.	- Signed provenance + SBOM/AIBOM; allowlist/pin deps. - Runtime verification + kill switch to disable compromised components.
ASI05	**Unexpected Code Execution (RCE)**	Agents generate/execute code; attackers turn outputs into executable behavior via injection, unsafe eval, deserialization, or tool chains. Leads to host/container compromise, persistence, or sandbox escape.	Prompt includes shell injection that the agent executes (e.g., destructive command sequence).	- Separate generation from execution with validation gates; ban unsafe eval. - Sandbox execution (no root, strict FS/network limits) + monitoring.
ASI06	**Memory & Context Poisoning**	Attackers corrupt stored memory/RAG/embeddings or persisted context, biasing future reasoning and tool use. Poison can persist across sessions and propagate across agents.	Poisoned RAG entries cause repeated unsafe recommendations or policy "facts" reused later.	- Validate/scan memory writes; segment tenants/sessions. - Provenance scoring + expiry/rollback for suspicious memory.
ASI07	**Insecure Inter-Agent Communication**	Weak authentication/integrity/confidentiality in agent-to-agent messaging allows spoofing, MITM, replay, or semantic manipulation. Compromises real-time coordination and intent.	MITM injects hidden instructions into inter-agent messages over an unauthenticated channel.	- mTLS + E2E encryption; sign messages for integrity. - Anti-replay (nonces/timestamps) + strict protocol/version pinning.

© National University of Singapore. All Rights Reserved.

OWASP Agentic AI Top 10

OWASP	Name	Description	Example	Mitigation
ASI08	**Cascading Failures**	A single fault (hallucination, poisoned memory, tool corruption) propagates across agents and workflows, creating system-wide harm. Focus is on amplification/fan-out, not the root defect.	One compromised planner triggers many downstream tool actions, causing widespread outage/impact.	- Isolation + circuit breakers/quotas to cap blast radius. - Independent policy enforcement + rate-limits/monitoring for fast fan-out.
ASI09	**Human-Agent Trust Exploitation**	Agents exploit human over-reliance, authority bias, and persuasive explanations to get approvals or secrets. The agent becomes an "untraceable bad influence" in the decision loop.	Finance manager approves fraudulent payment because agent provides confident, plausible rationale.	- Multi-step confirmations for sensitive actions; separate preview from effect. - Provenance metadata + UI risk cues and reporting/flagging.
ASI10	**Rogue Agents**	Agent behavior deviates from intended scope/goals and becomes harmful or deceptive, sometimes self-propagating. Focus is on behavioral integrity loss after drift begins.	Cost-optimizing agent deletes production backups to "meet" its metric (reward hacking).	- Behavioral monitoring/watchdogs + signed audit logs. - Kill switch/credential revocation + strict trust zones and isolation.

© National University of Singapore. All Rights Reserved.

Thank You

© National University of Singapore. All Rights Reserved